

Social Engineering Awareness Training

This guide explains common social engineering tactics used against employees and how to recognize and respond to them. Social engineering is the use of psychological manipulation to trick people into divulging confidential information or performing actions that compromise security.

1. Phishing

Phishing is a fraudulent attempt, usually via email, to obtain sensitive information (passwords, account numbers, credentials) or to get a user to click a malicious link or attachment by pretending to be a trustworthy entity.

- Look for mismatched or lookalike sender domains (e.g. "micros0ft.com").
- Be suspicious of urgent language: "Your account will be locked in 24 hours."
- Hover over links before clicking to check the real destination URL.
- Never enter credentials into a page reached via an unsolicited email link.

2. Spear Phishing and Whaling

Spear phishing targets a specific individual using personal details (name, role, recent projects) to appear legitimate. Whaling is spear phishing aimed at executives or other high-value targets, often impersonating a CEO or CFO to request wire transfers or sensitive data.

3. Pretexting

Pretexting involves inventing a fabricated scenario (a "pretext") to engage a target and extract information -- for example, an attacker posing as IT support asking an employee to "verify" their password, or as a vendor requesting account details to "process an invoice."

- Legitimate IT staff will never ask for your password.
- Verify unexpected requests through a known, separate channel (call the official help desk number, don't use contact info provided by the requester).

4. Baiting

Baiting lures victims with something enticing -- a free download, a USB drive labeled "Payroll 2026" left in a parking lot, or a too-good-to-be-true offer -- that installs malware or captures credentials when used.

- Never plug in unknown USB drives or external media.
- Report found devices to IT/Security rather than inspecting them yourself.

5. Tailgating and Piggybacking

Tailgating is following an authorized employee through a secured door without using your own badge, relying on politeness ("can you hold the door?"). Piggybacking is similar but the employee is aware and consents, which is still a policy violation.

- Always badge in yourself, even if someone is right behind you.
- Politely challenge or report unbadged individuals in secure areas.

6. Vishing and Smishing

Vishing (voice phishing) uses phone calls -- often spoofed caller ID -- to impersonate banks, government agencies, or internal IT. Smishing uses SMS text messages with malicious links or urgent requests for personal data.

7. Pharming and Fake Websites

Attackers may redirect users to a fraudulent look-alike website (via DNS manipulation or a convincing spoofed URL) that captures login credentials entered by unsuspecting victims.

8. Common Red Flags Checklist

- Unexpected urgency or threats (account suspension, legal action, missed deadlines).
- Requests for credentials, MFA codes, gift cards, or wire transfers.
- Generic greetings, spelling/grammar errors, or slightly-off branding.
- Requests to bypass normal approval processes "just this once."
- Unsolicited attachments or links, especially with unusual file types (.exe, .zip, .html).
- Callers or visitors who can't be verified through official channels.

9. What To Do If You Suspect Social Engineering

- Do not click links, open attachments, or provide any information.
- Report the incident immediately to IT/Security using official channels.
- If credentials may have been exposed, change your password and enable MFA right away.
- Preserve evidence (forward the email as an attachment; note the caller's number).

This document is for internal security awareness training purposes only.